

Practical Session 15: Privacy & Local Models

Hands-On: DP Budgets, NER De-identification, and a Membership-Inference Audit

Juan F. Imbet

Paris Dauphine – PSL University

June 20, 2026

Duration: 1 hour (50 min problems + 10 min debrief)

Timed agenda:

- ➊ **Recap** (8 min): DP definition, Gaussian mechanism, advanced composition, membership-inference AUC.
- ➋ **Problem 1** (12 min): Size the DP-SGD noise σ and spend a privacy budget across multiple fine-tunes.
- ➌ **Problem 2** (12 min): Build a financial NER de-identification mask by hand; reason about k -anonymity vs. contextual re-identification.
- ➍ **Case Study** (15 min): Run the membership-inference audit notebook in `code/notebooks/15-privacy-local-models/`; read the AUC.
- ➎ **Discussion** (10 min): on-prem vs. private cloud vs. anonymise-and-send.

Goal

Leave able to (a) cost a privacy budget, (b) hand-build a de-identification mask, and (c) interpret an empirical leakage metric.

Recap: The Formulas You Will Need

Gaussian mechanism (sets the noise scale)

$$\sigma = \frac{\Delta_2 f \cdot \sqrt{2 \ln(1.25/\delta)}}{\varepsilon}, \quad \mathcal{M}(D) = f(D) + \mathcal{N}(0, \sigma^2 I)$$

Advanced composition over k steps

$$\varepsilon' \approx \varepsilon \sqrt{2k \ln(1/\delta')}$$

DP-SGD clip: $\hat{g}_i = g_i / \max(1, \|g_i\|_2 / C)$ — bounds per-example sensitivity to C .

Membership-inference AUC: 0.5 = no leakage, 1.0 = total failure; < 0.6 commonly acceptable.

Two-layer NER pipeline

- Learned model: PERSON, ORG, LOCATION, MONEY, DATE
- Rules / regex: IBAN, ISIN, LEI, tax ID, SWIFT

Three strategies

- Masking: [PERSON_001]
- Generalisation: 75008 $\rightarrow$ Paris
- Suppression: remove span

k -anonymity

Output could plausibly come from $\geq k$ individuals. Masking gives large k — *but* context can still re-identify.

Pseudonymisation keeps text natural but the mapping is a key: GDPR Recital 26 $\Rightarrow$ protected, not anonymised.

Problem 1: Spending a Privacy Budget

Scenario. A bank fine-tunes a 7B model on credit-decision narratives with DP-SGD. Per-example gradients are clipped to $C = 1.0$. Target per-run guarantee: $\epsilon_{\text{run}} = 0.8$, $\delta = 10^{-5}$.

Task A. The aggregated clipped gradient has ℓ_2 -sensitivity $\Delta_2 f = C = 1.0$. Compute the noise scale σ for one mechanism application using the Gaussian mechanism. Use $\ln(1.25/10^{-5}) \approx 11.7$.

Task B. The team plans $k = 4$ independent fine-tuning runs over the year, each $(\epsilon_{\text{run}}, \delta)$ -DP. Using advanced composition with $\delta' = 10^{-5}$ (so $\ln(1/\delta') \approx 11.5$), what is the total budget ϵ' ?

Task C. The institution's annual privacy budget ceiling is $\epsilon_{\text{max}} = 5$. Are the four runs within budget? How many such runs can it afford before the ceiling is breached?

Problem 2: Build a De-identification Mask

Source sentence (relationship-manager call note):

“Spoke with Claire Moreau (LEI 969500TEST00CLAIRE12) about increasing the EUR 1,250,000 revolving facility; she will wire from IBAN DE89 3704 0044 0532 0130 00 once the board of Helvetia Trading SA approves on 12 March 2025.”

Task A. List every sensitive span and assign each a type (PERSON, ORG, MONEY, DATE, IBAN, LEI). Mark which need the *learned* model and which the *rule* layer.

Task B. Produce the fully *masked* version with typed placeholders ([PERSON_001], etc.), keeping co-references consistent.

Task C. Suppose the portfolio contains exactly one Swiss trading firm with a revolving facility near EUR 1.25m maturing in Q1 2025. Does masking achieve k -anonymity here? Which strategy (generalisation / suppression) would you add, and to which span?

Case Study: Membership-Inference Audit

Goal. Quantify how much a fine-tuned model leaks about its training set — the empirical check the chapter insists you run *after every fine-tune*.

Notebook: `code/notebooks/15-privacy-local-models/exercises.ipynb`

Figure generator: `gen_dp_privacy_utility.py` (privacy-utility curve).

The procedure:

- 1 Hold out a random subset of fine-tuning documents as the *non-member* (negative) class.
- 2 Score every member and non-member with the likelihood-ratio attack (target vs. reference model).
- 3 Sweep the decision threshold; plot the ROC; report the **AUC**.

Acceptance gate

$\text{AUC} \approx 0.5 \Rightarrow$ attack no better than chance (good). $\text{AUC} > 0.6 \Rightarrow$ leakage: add DP-SGD, reduce epochs, or exclude the most sensitive docs.

Case Study: The Audit Code (1/2 — the attack)

```
import numpy as np
from sklearn.metrics import roc_auc_score

# Per-document loss under target (fine-tuned) and reference models.
# Lower target loss on a doc => evidence it was a training member.
def membership_scores(target_loss, ref_loss):
    # Likelihood-ratio signal: high when target fits doc better than ref.
    return ref_loss - target_loss          # larger => more "member-like"

def audit_auc(target_loss, ref_loss, is_member):
    scores = membership_scores(target_loss, ref_loss)
    return roc_auc_score(is_member, scores)
```


Case Study: The Audit Code (2/2 — the toy run)

```
# Toy illustration: members fit noticeably better under the target model.
rng = np.random.default_rng(0)
ref      = rng.normal(2.0, 0.4, size=400)
member   = ref[:200] - rng.normal(0.6, 0.2, size=200)    # over-fit members
nonmemb  = ref[200:] - rng.normal(0.0, 0.2, size=200)    # no advantage
target   = np.concatenate([member, nonmemb])
is_member = np.array([1]*200 + [0]*200)

auc = audit_auc(target, ref, is_member)
print(f"membership-inference AUC = {auc:.3f}")
# Interpret: <0.6 acceptable; ~0.5 ideal; ->1.0 means severe leakage.
```

Case Study: Diagnostic Questions

Run the audit and the privacy-utility generator, then answer:

Q1. What AUC does the toy run report? Does it indicate acceptable privacy? Which array (`member` vs. `nonmemb`) drives the gap, and why?

Q2. Re-run `member` with the over-fit offset reduced from 0.6 to 0.0. What happens to the AUC, and what does that tell you about the link between over-fitting and membership leakage?

Q3. In `gen_dp_privacy_utility.py`, the curve is $\text{acc}(\epsilon) = 0.90 - (0.90 - 0.55)e^{-0.45\epsilon}$. Compute the modelled accuracy at $\epsilon = 1$ and $\epsilon = 10$. How large is the utility gap to the non-private baseline (0.90) in each case?

Q4 (link the two). You must keep $\text{MI-AUC} < 0.6$ *and* accuracy > 0.80 . Reading both results, is a single DP fine-tune at $\epsilon = 1$ likely to satisfy both? What lever (clip norm C , epochs, LoRA) would you pull first?

Discussion: Choosing the Deployment Pattern

For each scenario, pick **on-premise**, **private cloud**, or **anonymise-and-send to a cloud API** — and justify against regulation, sensitivity, latency, and cost.

- ❶ A relationship-manager assistant that routinely sees client names, account numbers, and transaction histories. Latency target: interactive.
- ❷ Summarising *public* ECB rate decisions for an internal newsletter — no client data, high volume, cost-sensitive.
- ❸ Joint fraud-detection model across three banks that legally cannot share raw transaction data with one another.
- ❹ Drafting a bond prospectus “Risk Factors” section from a structured issuer data dump and five precedent deals (internal, confidential, not personal data).

Frame your answer around

External boundary · data-residency · record-keeping (MiFID II) · DORA third-party terms · memorisation risk · latency · cost.

Solution: Problem 1 — Privacy Budget

Task A — noise scale ($\Delta_2 f = 1$, $\varepsilon_{\text{run}} = 0.8$, $\ln(1.25/10^{-5}) \approx 11.7$):

$$\sigma = \frac{1 \cdot \sqrt{2 \times 11.7}}{0.8} = \frac{\sqrt{23.4}}{0.8} \approx \frac{4.84}{0.8} \approx 6.05$$

Task B — four runs, advanced composition ($k = 4$, $\varepsilon = 0.8$, $\ln(1/\delta') \approx 11.5$):

$$\varepsilon' \approx \varepsilon \sqrt{2k \ln(1/\delta')} = 0.8 \sqrt{2 \times 4 \times 11.5} = 0.8 \sqrt{92} \approx 0.8 \times 9.59 \approx 7.67$$

Task C — against the ceiling $\varepsilon_{\text{max}} = 5$:

$$7.67 > 5 \Rightarrow \text{four runs exceed budget.}$$

Largest k with $0.8 \sqrt{2k \cdot 11.5} \leq 5$: $\sqrt{23k} \leq 6.25 \Rightarrow 23k \leq 39.1 \Rightarrow k \leq 1.7 \Rightarrow$ **only 1 run** fits under advanced composition at this ε_{run} . Lesson: budget is scarce — lower ε_{run} per run or fine-tune less often.

Solution: Problem 2 — De-identification Mask

Task A — spans and types:

Span	Type	Layer
Claire Moreau	PERSON	Learned
969500TEST00CLAIRE12	LEI	Rule
EUR 1,250,000	MONEY	Learned
DE89 3704 0044 0532 0130 00	IBAN	Rule
Helvetia Trading SA	ORG	Learned
12 March 2025	DATE	Learned

Task B — masked output: *“Spoke with [PERSON_001] (LEI [LEI_001]) about increasing the [MONEY_001] revolving facility; she will wire from IBAN [IBAN_001] once the board of [ORG_001] approves on [DATE_001].”*

Task C — re-identification. Masking does *not* achieve k -anonymity: “one Swiss trading firm, ~EUR 1.25m revolver, Q1 2025” is a near-unique fingerprint. Add **generalisation** — MONEY → “EUR 1–2m”, DATE → “Q1 2025” — and consider **suppressing** the ORG nationality cue. Goal: posterior over individuals stays diffuse.

APPENDIX

Stretch Problems

Extra / optional material — beyond the core lecture.

Appendix — Stretch Problem A: Gradient Inversion

Federated learning shares only gradient updates, never raw data — yet **gradient inversion** can reconstruct inputs from a single update.

A1. Explain why a FedAvg update Δ_k^t from a client training on one sensitive batch can leak that batch, and why *larger* local batch size and *more* local steps E both reduce the leakage.

A2. You add *local* DP-SGD before transmitting Δ_k^t . State the two new costs this imposes (relative to plain FedAvg) and why they are unavoidable.

A3. A cross-border bank runs one federated client per jurisdiction. Which regulation does this architecture specifically satisfy that pure centralised training would violate, and why does federation alone *not* discharge GDPR Art. 17?

Appendix — Stretch Problem B: Quantisation Audit

A risk team must sign off a 4-bit (AWQ) quantised, DP-fine-tuned model for on-prem deployment.

B1. The team worries quantisation might *change* the privacy guarantee. Argue, using the post-processing immunity property of DP, why quantising a DP-trained model does *not* weaken its (ϵ, δ) guarantee.

B2. AWQ needs a calibration set. Why is using a small *public* corpus (not client data) both sufficient for quality and necessary for privacy?

B3. 7B at 4-bit $\approx$ 3.5 GB. A branch workstation has a single 8 GB GPU. Estimate whether a 13B 4-bit model ($\approx$ 6.5 GB) also fits, and name one operational reason you might still prefer the 7B at the branch.